

CSRF where token validation depends on request method

Topic: CSRF | Difficulty: Practitioner

Description

The application validates CSRF tokens only for POST requests. When the same state-changing action (email change) is performed via a GET request the CSRF token validation is skipped entirely. An attacker can craft a URL that performs the action when clicked by an authenticated victim.

Steps to Exploit

1. Log in and capture the email change POST request in Burp Suite.
2. Note the CSRF token present in the POST body.
3. In Burp Repeater change the request method from POST to GET.
4. Move all parameters including email to the query string; omit the CSRF token.
5. Forward the GET request and observe the email change succeeds.
6. Craft the malicious GET URL and deliver it to the victim.

Proof of Concept

Original POST:

```
POST /my-account/change-email
```

```
email=test@test.com&csrf=TOKEN123
```

Bypassed GET:

```
GET /my-account/change-email?email=attacker@evil.com HTTP/1.1
```

Effect:

```
CSRF token validation skipped; email changed without a valid token.
```

Impact

- CSRF protection completely bypassed via HTTP method switch.
- Victim account email changed via a single URL click.
- Full account takeover via password reset to attacker-controlled email.

Mitigation / Remediation

1. Validate CSRF tokens on ALL state-changing requests regardless of HTTP method.
2. Reject GET requests for state-changing operations; enforce POST/PUT/DELETE.
3. Implement SameSite cookie attribute as a defense-in-depth measure.
4. Audit all endpoints for HTTP method consistency and CSRF coverage.

CVSS Score

CVSS v3.1: 6.5 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

CVSS Justification

- Attack Vector: Network - single malicious URL.
- Attack Complexity: Low.
- Privileges Required: None.
- User Interaction: Required - victim must click the link.
- Integrity: High - email and account hijacking.
- Confidentiality / Availability: None.